Chapter 5: Revision Sheet

Incident Response, Forensics & Cyber Laws — Last-Minute Read

#	Topic
1	Incident Response Lifecycle (6 phases)
2	CERT — Computer Emergency Response Team
3	Digital Forensics Techniques (7)
4	Top Forensics Tools (7)
5	Evidence Collection (4-step pipeline)
6	Chain of Custody
7	IT Act 2000 + Sections Table
8	DPDP Act 2023
9	GDPR vs HIPAA
10	IPR (Patents, Copyrights, Trademarks, etc.)
	Final Cheat Card

Legend: KEY = must-memorize · yellow box = dev/RWA Mind example to drop in exam · red box = exam gold

1. Incident Response Lifecycle

Analogy: Hospital ER handling a patient (the cyberattack).

```
+-------------------+
| 1. PREPARATION    |  <-- before anything: policies,
+---------+---------+      IRT, firewalls, drills
          |
          v
+-------------------+
| 2. DETECTION &    |  <-- SIEM, logs, "real or
|    ANALYSIS       |      false alarm?"
+---------+---------+
          |
          v
+-------------------+
| 3. CONTAINMENT    |  <-- short-term: yank cable
+---------+---------+      long-term: temp patch
          |
          v
+-------------------+
| 4. ERADICATION    |  <-- delete malware,
+---------+---------+      remove backdoors
          |
          v
+-------------------+
| 5. RECOVERY       |  <-- restore backups,
+---------+---------+      reconnect gradually
          |
          v
+-------------------+
| 6. LESSONS        |  <-- post-mortem, update
|    LEARNED        |      policies (feeds back to 1)
+---------+---------+
          |
          +-----> loops back to PREPARATION
```

1. **Preparation** — Build defense before incidents. Policies, IRT, firewalls, IDS/IPS, antivirus, drills.
2. **Detection & Analysis** — Identify if an incident occurred. SIEM tools, logs, confirm real vs false.
3. **Containment** — Limit damage. **Short-term** = immediate (disconnect). **Long-term** = temp solution till full fix.
4. **Eradication** — Remove root cause. Delete malware, kill backdoors, patch vulnerabilities.
5. **Recovery** — Restore from backups, reconnect gradually, monitor for relapse.
6. **Lessons Learned** — Document, find gaps, update policies/training. Feeds back into Preparation.

Dev example (RWA Mind): Imagine your DigiLocker access tokens leak. Detection = SIEM flags weird API patterns. Containment = revoke all tokens immediately (short-term), block IPs at Cloudflare (long-term). Eradication = patch the token-storage bug. Recovery = reissue tokens to users. Lessons = adopt token rotation + secret scanning in CI.

KEY MEMORIZE: All 6 phase names + 1-line goal. Cyclic — phase 6 feeds back to phase 1.

2. CERT — Computer Emergency Response Team

One-liner: A specialized team of cybersecurity experts who handle incidents for an org or country. India has **CERT-In** (national).

Analogy: Fire department of cybersecurity — they don't prevent every fire, but respond, investigate, and help prevent the next.

8 Roles in 4 Buckets (don't memorize as flat list)

```
              +------------------------------+
              |          C E R T             |
              +------------------------------+
                          |
   +---------+--------+--------+---------+
   |         |        |        |         |
 REACTIVE  PROACTIVE  INVESTI- PEOPLE &
                      GATIVE   PROCESS
   |         |          |         |
 1.Detect  3.Threat   5.Coord   7.Training
 2.Respond  Intel      6.Foren-   8.Policy
            4.Vuln      sics
            Mgmt
```

Bucket A — Reactive: (1) Incident Detection & Analysis (2) Incident Response

Bucket B — Proactive: (3) Threat Intelligence (4) Vulnerability Management

Bucket C — Investigative/Collab: (5) Coordination & Collaboration (6) Forensic Analysis

Bucket D — People & Process: (7) Training & Awareness (8) Policy Development

Dev example: If RWA Mind grew into a fintech with sensitive asset data, you'd register with CERT-In. They'd help with threat intel feeds (Bucket B), and you'd be legally required to report breaches to them within 6 hours under CERT-In rules.

KEY MEMORIZE: CERT definition + 4 buckets unfolding into 8 roles.

3. Digital Forensics Techniques (7)

Analogy: CSI for computers — preserve scene, collect evidence, analyze, report.

#	Technique	What it does	Tool / Example
1	Disk Imaging / Acquisition	Bit-by-bit copy of storage (HDD/USB) to preserve original	FTK Imager, dd
2	File Carving	Recover deleted files from unallocated space, ignoring file system metadata	Bulk Extractor
3	Memory Forensics	Analyze RAM for running processes, network conns, encryption keys	Volatility
4	Live Data Acquisition	Capture from running system before shutdown (volatile evidence)	—
5	Network Forensics	Monitor and analyze traffic for malicious activity	Wireshark
6	Email & Keyword Analysis	Search emails/metadata, recover deleted messages	—
7	Reverse Steganography	Detect hidden data inside images / other files	—

Volatile vs Non-volatile: Memory + Live = volatile (lost on power off). Disk = non-volatile.

Dev example: File carving is conceptually like recovering a dangling Git commit — the data is still there in `.git/objects` even after a branch delete; it's just unreferenced. Forensic tools do the same on disk: scan unallocated sectors and reassemble files by their headers/footers.

KEY MEMORIZE: All 7 techniques + 1-line definition each. Know which are volatile.

4. Top Digital Forensics Tools (7)

Trick: Names hint at purpose — Volatility = volatile RAM, FTK *Imager* = images, Wireshark = network.

Tool	Purpose	Quick recall
Autopsy	Open-source GUI for disk image analysis & reports	"Free Autopsy"
Magnet AXIOM	Multi-source: computers, phones, cloud	"Magnet pulls from everywhere"
EnCase	Commercial all-rounder for collection & analysis	Enterprise choice
Volatility Framework	Memory (RAM) forensics specifically	Volatile = RAM
FTK Imager	Creating fast forensic disk images	Imager = images
Bulk Extractor	Pulls URLs, emails, etc. from disk images	Extracts in bulk
Wireshark	Network protocol analyzer (live traffic)	You already know it

Dev example: Wireshark you've used while debugging API calls. If RWA Mind's WhatsApp webhook ever misbehaved, Wireshark on the receiving server would show you the exact packets — same way it'd show a forensic investigator a malicious payload.

KEY MEMORIZE: Pair each tool with its primary purpose. They love (tool, purpose) MCQs.

5. Evidence Collection — 4-Step Pipeline

```
+------------+    +------------+    +----------+    +-----------+
|    DATA    | -> |EXAMINATION | -> | ANALYSIS | -> | REPORTING |
| COLLECTION |    |            |    |          |    |           |
+------------+    +------------+    +----------+    +-----------+
     |                                                    |
     v                                                    v
  MEDIA  ------>  DATA  ------>  INFORMATION  ------>  EVIDENCE
```

1. **Data Collection** — Identify sources (PCs, phones, servers). Collect WITHOUT modifying originals. Use forensic tools to make copies.
2. **Examination** — Inspect collected data, filter relevant info, detect hidden/deleted/encrypted files, organize.
3. **Analysis** — Interpret evidence, find patterns/relationships, reconstruct events (timeline).
4. **Reporting** — Document findings, mention tools/methods used, prepare for legal authorities.

Dev example: This is literally a RAG pipeline for evidence — Ingest → Process → Analyze → Output. RWA Mind does the same thing, just for asset documents instead of crime evidence: PDFs come in (Media), get parsed (Data), get embedded + linked (Information), and become a queryable knowledge base (Evidence-equivalent: queryable answers).

KEY MEMORIZE: 4 stages + the Media-Data-Info-Evidence flow.

6. Chain of Custody

One-liner: A documented, chronological record of who handled the evidence, when, and what they did — from seizure to courtroom.

Killer analogy: Like **git commit history for evidence**. Every change, every handoff, fully logged and tamper-evident. Break the chain = like a force-pushed branch — history is now untrusted.

```
COLLECTION --> PRESERVATION --> DOCUMENTATION --> ANALYSIS --> PRESENTATION
    |              |                  |              |              |
 log who/      Faraday bags,      form travels   work on a       court
 where/        hard drive         with evidence   COPY, never    proves
 when          imaging            everywhere      original       unaltered
```

4 Key Components

1. **Documentation** — Logs of every person who touched it + timestamps.
2. **Unique Identifier** — Each piece of evidence gets a unique ID (like a primary key in your DB).
3. **Hashing** — Cryptographic hash (MD5/SHA-256) = digital fingerprint. ANY change = different hash = tampering detected.
4. **Storage & Security** — Physical + digital safeguarding (locked rooms, encrypted drives).

5 Process Steps

1. **Collection** — Grab evidence; log device/location/who.
2. **Preservation** — Protect from alteration. **Faraday bags** for phones (block signals so nobody can remote-wipe), image hard drives.
3. **Documentation** — Chain of Custody Form travels with evidence everywhere.
4. **Analysis** — Done on a **COPY**, NEVER the original.
5. **Presentation** — Show in court; documentation proves it's unchanged from time of seizure.

Consequences of Broken Chain: Evidence = **inadmissible in court**. Case can be dismissed even if evidence is damning.

Dev example: Same idea as Git's SHA-1 hashing — change one byte in a file, hash changes completely, you instantly know history was tampered with. RWA Mind uses content hashes for documents too: if a property paper's hash changes, our system knows the doc was modified and can flag it for re-verification.

KEY MEMORIZE: Definition + 4 components + 5 steps + 'broken = inadmissible'. Faraday bag example is exam gold.

7. Information Technology Act, 2000 (IT Act)

One-liner: India's primary cyber law — legal framework for electronic transactions, digital governance, and cybercrime prevention.

5 Key Features

1. **Digital Signatures** — Legal recognition for e-signatures (e.g., Aadhaar e-sign). Ensures authenticity/integrity of online docs.
2. **Cybercrime Regulation** — Defines & penalizes hacking, identity theft, cyber terrorism, cyberstalking.
3. **Cyber Cafes** — Defined as public internet places; must keep user identity records.
4. **Overriding Provisions** — IT Act trumps conflicting laws in cyber matters; doesn't override Copyright Act 1957.
5. **Regulation of Digital Media** — Rules for social media, grievance redressal, data privacy.

Sections Table — MUST KNOW

Section	Offense	Penalty
43	Unauthorized access / damage to computer systems	Compensation to system owner
66	Hacking a computer system	Up to 3 yrs OR Rs.5 lakh OR both
66B, C, D	Fraud and identity theft	Up to 3 yrs OR Rs.1 lakh OR both
66E	Privacy violation (transmitting private images)	Up to 3 yrs OR Rs.2 lakh OR both
66F	Cyber terrorism (against India sovereignty)	LIFE IMPRISONMENT
67	Publishing obscene content online	Up to 5 yrs OR Rs.10 lakh OR both

Memory tricks:

- **43** = foundation, just compensation (no jail).
- **66** = main hacking, Rs.5 lakh.
- **66B/C/D** = fraud/identity = lower fine Rs.1 lakh.
- **66E** = privacy/private images = Rs.2 lakh ('E' for Embarrassment).
- **66F** = cyber terrorism = LIFE imprisonment ('F' for Final).
- **67** = obscenity = biggest fine Rs.10 lakh, 5 yrs.

KEY MEMORIZE: All 6 rows of the section table. Almost guaranteed to come.

8. Digital Personal Data Protection (DPDP) Act, 2023

One-liner: India's data protection law (Aug 2023, strengthened by DPDP Rules 2025) — regulates digital personal data processing.

Scope: Applies inside India + outside if serving Indian residents (extraterritorial, like GDPR).

Two Key Roles

```
+-------------------+        consent        +--------------------+
|  DATA PRINCIPAL   | <-------------------> |  DATA FIDUCIARY    |
|  (the individual) |                       |  (entity handling  |
|  i.e. YOU         |    obligations to     |  the data)         |
+-------------------+    protect & honor    +--------------------+
                         principal's rights
```

Data Principal = the individual whose data it is (you).

Data Fiduciary = entity processing the data (RWA Mind would be one).

Like a bank: you're the principal (owner), bank is the fiduciary (entrusted to handle responsibly).

6 Key Highlights

1. **Data Principal Rights** — Access, correct, erase, withdraw consent.
2. **Data Fiduciary Obligations** — Notice, clear consent, accuracy, **delete after purpose met**.
3. **Child Protection** — Under-18s need parental consent; harmful targeted ads at kids = banned.
4. **Significant Data Fiduciaries (SDF)** — Govt-designated big players; must appoint a Data Protection Officer (DPO), do impact assessments + audits.
5. **Penalties** — Up to **Rs.250 crore** for failing to prevent breaches.
6. **Data Protection Board of India** — Regulator; monitors compliance, hears complaints, imposes fines.

Dev example (RWA Mind): Since you store sensitive asset docs (property papers, insurance, DigiLocker pulls), you'd be a Data Fiduciary. Scale big enough = Significant Data Fiduciary, legally needing a DPO. The 'delete after purpose met' rule directly affects how long you can retain user docs after they delete an asset from their vault.

KEY MEMORIZE: Definition + Principal vs Fiduciary + 6 highlights + Rs.250 crore figure.

9. GDPR & HIPAA — International Frameworks

Quick frame: GDPR = broad (all personal data, global reach, huge fines). HIPAA = narrow (health data only, US-only, sector-specific).

GDPR — General Data Protection Regulation (EU)

- **Scope:** Personal data of EU/EEA residents.
- **Application:** Extraterritorial — applies globally if you process EU data.
- **Requirements:** Lawful basis, privacy notices, **72-hour breach notification**, strict data subject rights.
- **Penalty:** Up to **EUR 20M or 4% of global annual turnover** (whichever higher).

HIPAA — Health Insurance Portability & Accountability Act (USA)

- **Scope:** Protected Health Information (PHI).
- **Application:** US healthcare providers, health plans, business associates.
- **Requirements:** Administrative, physical & technical safeguards + breach notification.
- **Penalty:** Tiered, $100 to $1.5M per violation.

Comparison Table — MUST KNOW

Aspect	GDPR	HIPAA
Data type	All personal data (name, email, IP, location, etc.)	PHI (health-related only)
Jurisdiction	EU residents (global reach)	US healthcare sector
Consent	Clear, informed, explicit	Treatment / payment / operations-based
Penalty	EUR 20M or 4% global revenue	$100 - $1.5M per violation
Subject rights	Access, correct, delete, restrict, transfer	Access + correct PHI only

Dev example: If RWA Mind expanded to EU users (e.g., property assets in Portugal), GDPR kicks in — you'd need a lawful basis (consent), privacy notice, 72-hr breach reporting. If you ever stored US patient health data (you don't, but hypothetically), HIPAA would apply. Both can require ISO 27001 / NIST compliance frameworks underneath.

KEY MEMORIZE: 72-hour GDPR breach rule, EUR 20M / 4%, the comparison table, PHI = HIPAA only.

10. Intellectual Property Rights (IPR)

One-liner: Legal protections for creations of the mind — innovations, art, brand identity, regional products.

Piracy = unauthorized reproduction/use of copyrighted content (torrents, pirated software, etc.).

Type	Protects	Duration	Example
Patents	New inventions (products/processes); novel, non-obvious, useful	20 years	Drug formula, unique algorithm
Copyrights	Original creative works (literature, music, software, films)	Author lifetime + 60 yrs (India)	Source code, novel, song
Trademarks	Brand identifiers (logos, names, symbols)	Renewable indefinitely	Nike swoosh, Apple logo
Trade Secrets	Confidential business info giving competitive edge	As long as kept secret	Coca-Cola formula, Google search algo
Geographical Indications (GI)	Region-specific quality/reputation goods	Region-tied	Darjeeling tea, Banarasi sarees, Champagne

Dev example (RWA Mind — ALL 5 apply!):

• **Copyright** — Your codebase is automatically copyrighted the moment you write it.

• **Trademark** — 'RWA Mind' as a brand name + logo can be trademarked.

• **Trade Secret** — Your specific cross-document contradiction-detection algorithm can be kept as a trade secret (or patented — pick one).

• **Patent** — If the temporal knowledge graph approach is novel and non-obvious, it could potentially be patented (20 yrs).

• **GI** — Doesn't apply to RWA Mind directly, but if a user stores 'Darjeeling tea estate' as an asset, the GI on 'Darjeeling' is what makes that estate valuable.

KEY MEMORIZE: 5 types + duration + 1 example each. Durations are commonly asked.

Final Cheat Card — Glance Right Before Exam

IR Lifecycle (6)

Preparation -> Detection & Analysis -> Containment (short/long) -> Eradication -> Recovery -> Lessons Learned (loops back).

CERT — 8 roles in 4 buckets

Reactive: Detect, Respond **|** Proactive: Threat Intel, Vuln Mgmt **|** Investigative: Coord, Forensics **|** People: Training, Policy.

Forensics Techniques (7)

Disk Imaging, File Carving, Memory, Live, Network, Email/Keyword, Reverse Steganography.

Forensics Tools (7)

Autopsy (open-source disk), Magnet AXIOM (multi-source), EnCase (commercial), Volatility (RAM), FTK Imager (imaging), Bulk Extractor (URLs/emails), Wireshark (network).

Evidence Pipeline

Data Collection -> Examination -> Analysis -> Reporting **|** Media -> Data -> Information -> Evidence.

Chain of Custody

Components: Documentation, Unique ID, Hashing, Storage. Steps: Collection -> Preservation (Faraday bag) -> Documentation -> Analysis (on COPY) -> Presentation. Broken chain = inadmissible.

IT Act Sections (memorize cold)

43 = unauth access (compensation); 66 = hacking (3yr/Rs.5L); 66B-D = fraud/ID (3yr/Rs.1L); 66E = privacy/images (3yr/Rs.2L); **66F = cyber terrorism (LIFE)**; 67 = obscenity (5yr/Rs.10L).

DPDP Act 2023

Data Principal vs Data Fiduciary. Rights: access/correct/erase/withdraw. Fines up to Rs.250 crore. Big players = SDF (need DPO). Regulator = Data Protection Board of India.

GDPR vs HIPAA

GDPR: EU/EEA, all personal data, 72-hr breach, EUR 20M or 4%. HIPAA: US healthcare PHI, $100-$1.5M/violation. GDPR = broad, HIPAA = narrow.

IPR Durations

Patent = 20 yrs **|** Copyright = lifetime + 60 yrs (India) **|** Trademark = renewable forever **|** Trade Secret = while secret **|** GI = region-tied.

Exam Tactics

- Start every answer with a **1-line definition**, then bullets, then 1 example.
- For comparison Qs (GDPR vs HIPAA, etc.) — **use a table**. Examiners love it.
- For diagram Qs — draw + label + 1 line per element.
- Stuck on a section number? Write a partial answer ('Section 66 deals with hacking, ~3 years OR fine') — partial > blank.
- Drop your RWA Mind / DigiLocker / WhatsApp examples in DPDP, IPR, IR Lifecycle, GDPR — instant points for application.

You got this bro. Walk in calm.